

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

QILIN KOREAN LEAKS
RANSOMWARE OLAYI İNCELEME
RAPORU
Eray Atalay





İçindekiler

İçindekiler	1
1. Yönetici Özeti	2
2. Tehdit Aktörü Profili	2
2.1 Grubun Kökeni ve Gelişim Süreci	2
3. Olayın Genel Analizi	3
4. Teknik Analiz	4
4.1 Initial Access (İlk Erişim)	4
4.2 Lateral Movement (Yanal Hareket)	4
4.3 Exfiltration (Veri Sızdırma)	4
5. MITRE ATT&CK Mapping	5
6. IOC ve TTP Bulguları	6
IOC	6
Domain ve IP Bulguları	6
SHA-256	6
Komutlar ve Kayıt Defteri Öğeleri	6
TTP	7
7. Risk Değerlendirmesi	8
8. Savunma ve Mitigation Önerileri	8
Strict MFA ve IAM	8
Network Segmentation & Zero Trust	8
EDR ve Davranışsal Analiz	8
Immutable Backups	8
9. Sonuç ve Genel Değerlendirme	9
10. Kaynakça	10



1. Yönetici Özeti

Eylül-Ekim 2025 tarihlerinde Güney Kore finans ve varlık yönetimi sektörünü hedef alan ve "Korean Leaks" olarak bilinen bir fidye yazılımı saldırısı gerçekleşmiştir. Qilin (Ransomware-as-a-Service) grubu tarafından koordine edilen operasyonda, saldırganlar kurumları tek tek hedef almak yerine "GJTec" isimli bir Yönetilen Hizmet Sağlayıcısı' nı (MSP) ele geçirerek eş zamanlı olarak 28 downstream finans organizasyonuna sızmıştır. Çifte Şantaj (Double Extortion) yönteminin kullanıldığı olayda, 1 milyondan fazla dosya ve yaklaşık 2 TB veri çalınmış, fidyenin ödenmemesi üzerine veriler üç dalga halinde sızdırılmıştır. Bu olay, MSP' lere olan güvenin nasıl kritik bir zafiyete dönüşebileceğini ve modern RaaS operasyonlarının tedarik zincirlerindeki boşlukları nasıl istismar ettiğini açıkça göstermektedir.

2. Tehdit Aktörü Profili

Profil Özelliği	Detaylar
Aktör / Grup Adı	Qilin (Eski adıyla "Agenda")
İlk Görülme Tarihi	Ağustos 2022 - Günümüz
Motivasyon	Finansal Kazanç
Operasyon Modeli	Ransomware-as-a-Service (RaaS)
Menşei / Coğrafi Bağlantı	Doğu Avrupa ve Rusça konuşan siber suç (RU-Net) ekosistemi ile güçlü bağlar. Yeraltı forumlarındaki iletişim dilleri ve hedeflenen bölge dışlamaları (CIS ülkelerine saldırmama eğilimi) bu durumu desteklemektedir.
Hedef Sektörler	Finans ve Varlık Yönetimi, Sağlık Sektörü, Kritik Altyapılar, Eğitim ve Yönetilen Hizmet Sağlayıcıları.
Şantaj Stratejisi	Verileri şifrelemeden önce komuta kontrol sunucularına veya MEGA gibi bulut servislerine sızdırarak kurban üzerinde regülasyon ve itibar baskısı kurma.

2.1 Grubun Kökeni ve Gelişim Süreci

Qilin, ilk olarak 2022 yılının ortalarında "Agenda" adıyla siber tehdit ekosisteminde faaliyet göstermeye başlayan, ardından aynı yılın sonlarına doğru kendisini "Qilin" olarak yeniden markalaştıran, finansal motivasyonu yüksek bir fidye yazılımı grubudur. Grubun operasyonel altyapısı, sızıntı siteleri (Dedicated Leak Sites - DLS) ve yeraltı forumlarındaki iletişim dilleri incelendiğinde, Doğu Avrupa ve Rusya coğrafyası merkezli siber suç ekosistemleriyle güçlü bağları olduğu değerlendirilmektedir. İlk dönemlerinde daha çok küçük ve orta ölçekli işletmeleri (KOBİ) hedef alan grup, zamanla taktiksel olgunluğa erişerek kritik altyapı sağlayıcılarını, sağlık sektörünü ve finansal kuruluşları hedef alan bir stratejiye geçiş yapmıştır.



3. Olayın Genel Analizi

Korean Leaks: Operasyon Kronolojisi



Hedef Sektör ve Tarih: Güney Kore finansal hizmetler ve varlık yönetimi sektörü (Eylül - Ekim 2025).

Saldırı Vektörü: Tedarik Zinciri İhlali (Supply Chain Compromise) – GJTec adlı BT sağlayıcısı üzerinden sızma.

Veri Sızıntısı: Çalınan 2 TB verinin Qilin'in Dedicated Leak Site (DLS) platformunda 14 Eylül, 17-19 Eylül ve 28 Eylül-4 Ekim tarihlerinde periyodik olarak ifşa edilmesi.

Organizasyonel Etkiler: Şifrelenen varlık yönetim sistemleri nedeniyle operasyonların durması, yasal uyumluluk riskleri (müşteri finansal verilerinin ifşası) ve ciddi itibar kaybı.



4. Teknik Analiz

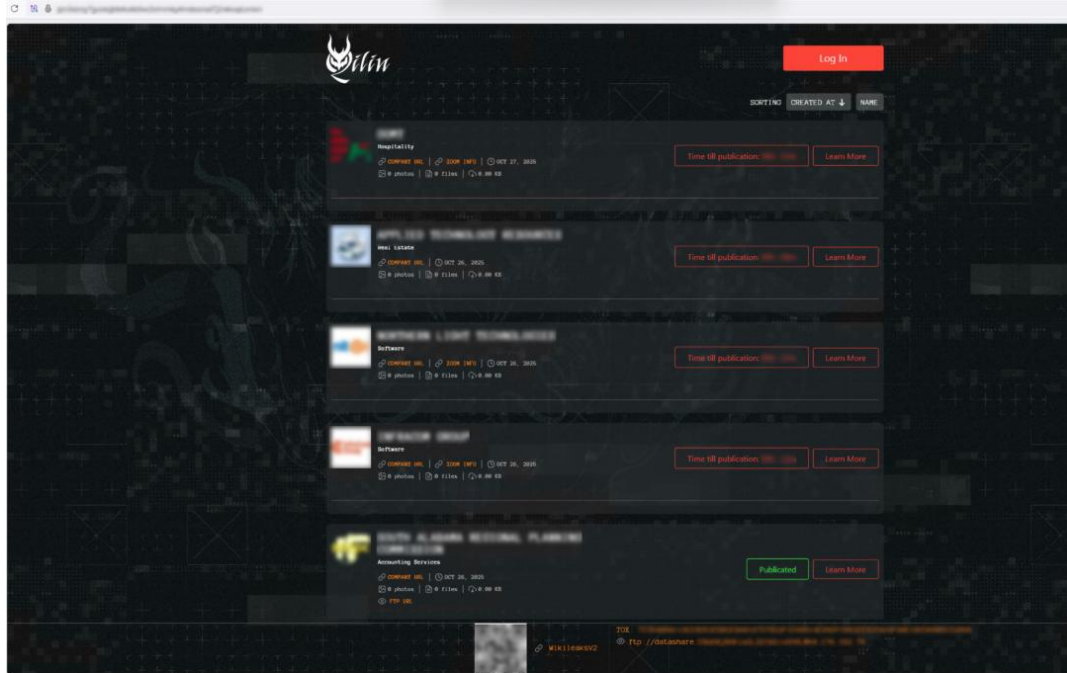
4.1 Initial Access (İlk Erişim)

Qilin, Güney Kore finans kurumlarına doğrudan sızmaya çalışmak yerine farklı bir yaklaşım benimseyerek hedef kurumların BT altyapılarını yöneten "GJTec" isimli Yönetilen Hizmet Sağlayıcısı'nı (MSP) hedef almıştır. Bu ilk erişimin, genellikle Rusça konuşulan yeraltı forumlarında (RU-Net) faaliyet gösteren Initial Access Broker'lar (IAB) tarafından satılan "Infostealer" loglarından veya Fortinet/Citrix gibi uç ağ cihazlarındaki yamalanmamış zafiyetlerin sömürülmesiyle elde edildiği değerlendirilmektedir. Çok faktörlü kimlik doğrulaması (MFA) bulunmayan VPN ve RDP kanalları üzerinden geçerli kimlik bilgileriyle ağa girilmiş, bu sayede saldırganlar güvenlik duvarlarında herhangi bir alarm üretmeden "meşru bir sistem yöneticisi" profili çizmiştir.

4.2 Lateral Movement (Yanal Hareket)

Ağ içerisinde yayılmak için "Living off the Land" (LotL) taktikleri benimsenmiştir. Salırganlar ağ haritasını çıkardıktan sonra, yanal hareket ve ayrıcalık yükseltmek için Cobalt Strike, PsExec, SSH ve RDP gibi yasal sistem ve uzaktan erişim araçlarını kullanmışlardır. Özellikle ScreenConnect gibi MSP uzaktan yönetim konsollarının kötüye kullanılması, fidye yazılımının bağlı 28 kuruma aynı anda dağıtılmasına olanak tanımıştır. Güvenlik çözümlerini (EDR/Antivirüs) atlatmak için sistemler "Safe Mode with Networking" (Ağ Destekli Güvenli Mod) durumunda yeniden başlatılmış ve User Account Control'ü (UAC) devre dışı bırakmak için Windows AppInfo süreçleri sonlandırılmıştır.

4.3 Exfiltration (Veri Sızdırma)



Görsel 1: Qilin DLS

Qilin operasyonlarında veri dışarı çıkarılırken genellikle MEGA gibi bulut depolama servisleri veya gizli Command-and-Control (C2) kanalları üzerinden SSL şifreli tüneller kullanılır. Çifte şantaj modelinin uygulandığı bu saldırıda, hedeflerin kritik müşteri ve finansal dosyaları dışarı aktarıldıktan sonra Rust tabanlı fidye yazılımı ile sistemler şifrelenmiştir. Fidye baskısını artırmak ve geri yüklemeyi imkansız kılmak adına MBR/VBR boot sektörlerine müdahale edilmiş ve Volume Shadow Copy (VSS) dosyaları geri döndürülemez şekilde silinmiştir.



5. MITRE ATT&CK Mapping

Taktik (Tactic)	Teknik ID	Teknik Adı	Olaydaki Kullanımı
Initial Access	T1199	Trusted Relationship	GJTec adlı Yönetilen Hizmet Sağlayıcısı'nın (MSP) ele geçirilerek bağlı 28 finans kurumuna erişilmesi.
Initial Access	T1190	Exploit Public-Facing Application	İlk sızma aşamasında yamanmamış VPN portallarının ve ağ geçitlerinin istismar edilmesi.
Execution	T1059.001	PowerShell	Zararlı yüklerin indirilmesi ve çalıştırılması için PowerShell betiklerinin kullanılması.
Defense Evasion	T1562.001	Impair Defenses	Güvenlik yazılımlarını atlatmak için sistemlerin "Safe Mode" ile başlatılması ve UAC'nin atlatılması.
Credential Access	T1003.001	LSASS Memory	Ağ içinde daha yetkili hesaplara geçiş yapmak için LSASS bellek dökümü alınarak parolaların çalınması.
Lateral Movement	T1543.003	Windows Service	Uzak sistemlerde zararlı kod çalıştırmak ve yayılmak için PsExec aracının kullanılması.
Exfiltration	T1567.002	Exfiltration Over Web Service	Çifte şantaj için çalınan 2 TB verinin MEGA gibi bulut depolama servisleri üzerinden dışarı aktarılması.
Impact	T1490	Inhibit System Recovery	Sistem geri yüklemelerini engellemek için Volume Shadow Copy (VSS) dosyalarının silinmesi.
Impact	T1486	Data Encrypted for Impact	Sistemdeki verilerin Rust tabanlı Qilin fidye yazılımı varyantı ile şifrelenmesi.



6. IOC ve TTP Bulguları

IOC

Domain ve IP Bulguları

cloudflariz[.]com
cloudflariz[.]com/comm.php
cloudflariz[.]com/auload.php
68[.]65[.]122[.]246
104[.]21[.]63[.]167

SHA-256

hosts.exe A51C8FCDE0BCC9FE8273F99C8B23E63CA4CD0F66B22CADD0BCB0F3ADB0FA05FA
dato.exe A4E3F6633F3ECECD39F0BA8C9644962BB0DD677EE0ECF22A99986D5C80E34BD7
[Unique ID]_crypt.exe 1306A6B3D73CD4DDE97DC3D6407AE783A91C5F312AE77E5CF88674FC99C7CAF0

Komutlar ve Kayıt Defteri Öğeleri

reg.exe [add "hkey_local_machine\system\currentcontrolset\control\terminal server" /v fdenytsconnections /t reg_dword /d 0 /f]
%COMSPEC% /Q /c echo cd ^> \\127.0.0.1\C\$__output 2^>^&1 > %TEMP%\execute.bat & %COMSPEC% /Q /c %TEMP%\execute[.]bat & del %TEMP%\execute.bat\r\n



TTP

MITRE Teknik (ID ve Adı)	Olaydaki Kullanımı
T1199 - Trusted Relationship	Saldırganların hedef finans kurumlarına doğrudan saldırmak yerine, bu kurumlara hizmet veren "GJTec" isimli Yönetilen Hizmet Sağlayıcısı'nın (MSP) altyapısını ele geçirerek 28 farklı kuruma sızması.
T1190 - Exploit Public-Facing Application	Ağa ilk giriş aşamasında dışa açık, çok faktörlü kimlik doğrulaması (MFA) bulunmayan veya zafiyet barındıran VPN portallarının ve ağ geçitlerinin istismar edilmesi.
T1059.001 - PowerShell	Zararlı yazılımların bellekte (in-memory) çalıştırılması ve güvenlik önlemlerini atlatmak amacıyla Base64 ile şifrelenmiş zararlı betiklerin yürütülmesi.
T1562.001 - Impair Defenses	Antivirüs ve EDR çözümlerini atlatmak için kurban sistemlerin "Ağ Destekli Güvenli Mod" ile yeniden başlatılmaya zorlanması ve UAC'yi atlatmak için ApplInfo prosesinin kapatılması.
T1003.001 - LSASS Memory	Ağ içerisinde daha yetkili hesaplara geçiş yapabilmek (Privilege Escalation) amacıyla LSASS belleğinden kullanıcı parolalarının (Credential Dumping) çalınması.
T1543.003 - Windows Service	MSP'nin yasal uzak bağlantı araçlarına (ScreenConnect vb.) ek olarak, ağ içinde yanal hareket (Lateral Movement) ve zararlı kod çalıştırmak için PsExec aracının kullanılması.
T1567.002 - Exfiltration Over Web Service	Çifte şantaj baskısı kurmak amacıyla kurumdan çalınan 2 TB boyutundaki verinin MEGA gibi dış bulut depolama servislerine aktarılması.
T1490 - Inhibit System Recovery	Kurumun sistemleri şifrelendikten sonra geri yükleme yapmasını engellemek için vssadmin aracı ile Volume Shadow Copy (Gölge Kopya) yedeklerinin sessizce silinmesi.
T1486 - Data Encrypted for Impact	Veri hırsızlığı tamamlandıktan sonra, Rust tabanlı Qilin fidye yazılımı kullanılarak tüm kritik dosyaların şifrelenmesi ve operasyonların durdurulması.



7. Risk Değerlendirmesi

Qilin grubunun Güney Kore finans sektörüne yönelik operasyonu incelendiğinde, ortaya çıkan risk tablosu geleneksel izole saldırıların ötesine geçerek sistematik bir nitelik kazanmış ve yetersiz Yönetilen Hizmet Sağlayıcısı (MSP) güvenliğinin nasıl bir tehlike yarattığını kanıtlamıştır. Hedef kurumların Üçüncü Taraf Risk Yönetimi (TPRM) süreçlerindeki boşluklarından faydalanılmasıyla birlikte saldırının etki yarıçapı, tek bir güvenli bağlantı üzerinden 28 farklı finans organizasyonuna genişlemiştir. Ayrıca, uygulanan çifte şantaj stratejisi kapsamında çalınan 2 TB boyutundaki hassas müşteri verisinin sızdırılması, kurumları yalnızca operasyonel körlükle değil, ağır regülatif cezalar ve yasal uyumluluk ihlalleriyle de baş başa bırakmıştır. Finans sektörü gibi tamamen güvene dayalı bir ekosistemde yaşanan bu büyük çaplı ihlal, uzun vadeli müşteri güveni kaybı, yasal yaptırımlar ve onarılması zor bir itibari ve finansal yıkım ile sonuçlanan çok boyutlu bir risk profili ortaya koymaktadır.

8. Savunma ve Mitigation Önerileri

Strict MFA ve IAM

Kurum ağına ve özellikle MSP uzaktan erişim portallarına girişlerde çok faktörlü kimlik doğrulamanın (MFA) zorunlu kılınması.

Network Segmentation & Zero Trust

MSP ağ bağlantıları ile kurumun kritik Active Directory ve finansal veri tabanı ağlarının birbirinden izole edilmesi.

EDR ve Davranışsal Analiz

Qilin'in kullandığı "Living off the Land" tekniklerini (PsExec, Cobalt Strike) imza tabanlı araçlar yakalayamaz. Anomali tespiti yapan, UAC bypass girişimlerini engelleyen EDR çözümleri şarttır.

Immutable Backups

Saldırganların sistem yedeklerini (VSS) silme davranışına karşı, ağdan tamamen izole edilmiş ve dışarıdan değiştirilemez yedekleme mimarilerinin kurulması.

9. Sonuç ve Genel Değerlendirme

Qilin fidye yazılımı grubunun gerçekleştirdiği "Korean Leaks" operasyonu, modern siber suç ekosisteminde tehdit aktörlerinin hedef küçültüp etkiyi maksimuma çıkarmak amacıyla doğrudan kurumlar yerine tedarik zinciri zafiyetlerine yöneldiği kritik bir hedef değişimini temsil etmektedir. Saldırganların hedef finans kurumlarının çevre güvenliklerini aşmaya çalışmak yerine GJTec (MSP) altyapısını ele geçirerek tek bir güvenilir bağlantı üzerinden eşzamanlı olarak 28 farklı kuruma sızması ve gelişmiş Rust tabanlı zararlılarla "Living off the Land" taktiklerini birleştirmesi, RaaS (Ransomware-as-a-Service) yapılarının artık APT (Gelişmiş Kalıcı Tehdit) seviyesinde operasyonel olgunluğa ulaştığını göstermektedir. Buna ek olarak, çalınan 2 TB boyutundaki verinin zamana yayılan dalgalar halinde ifşa edildiği çifte şantaj stratejisi, finans sektörü gibi güven odaklı yapılarda siber savunmanın salt bir BT problemi olmaktan çıkıp en hayati iş sürekliliği ve itibar riski haline geldiğini kanıtlamıştır. Bu asimetrik tehdit ortamında, kurumların geleneksel reaktif güvenlik yaklaşımlarını terk ederek, aktif tehdit avcılığı, sıkılaştırılmış kimlik-erişim yönetimi (IAM) ve Zero Trust mimarisine dayanan, veri sızıntısını temelden engelleyen proaktif bir savunma postürüne geçiş yapmaları kaçınılmaz bir sektörel zorunluluktur.



10. Kaynakça

<https://www.linkedin.com/pulse/korean-leaks-analyzing-hybrid-geopolitical-campaign-targeting-yrv9f/>

<https://industrialcyber.co/ransomware/ransomware-sector-reconsolidating-as-qilin-lockbit-and-the-gentlemen-expand-influence-in-q1-2026/>

<https://thehackernews.com/2025/11/qilin-ransomware-turns-south-korean-mssp.html>

<https://www.osibeyond.com/blog/qilin-ransomware-remains-a-major-threat-to-smbbs/>

<https://www.threatlocker.com/blog/qilin-raas-group-technical-analysis-from-initial-access-to-beaconing>

<https://research.checkpoint.com/2026/the-state-of-ransomware-q1-2026/>

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

